

# Clase 340 — Capstone: pentest autorizado asistido por IA con MCP

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: kali-mcp (MIT) · PTES · integra las Partes 3–9 y 18  
⌚ Duración estimada: **180+ min** · Nivel: **Experto**

⚠ **Autorización obligatoria.** Este capstone se realiza **exclusivamente** contra una VM vulnerable **de tu propiedad** en una **red aislada**. Redacta tu propio documento de alcance y autorización antes de empezar. Nunca contra sistemas de terceros.

## 🎯 Objetivo

Integrar todo el programa en una operación completa: montar kali-mcp, definir el alcance, ejecutar un pentest **supervisado** asistido por IA contra tu laboratorio (recon → auditoría → PoC de bajo impacto → informe), aplicando los guardrails y la ética de las clases anteriores. Es la síntesis de las Partes 3–9 (técnica) y 18 (IA como copiloto).

## 📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Planificar** un engagement de laboratorio con alcance, RoE y guardrails escritos.
2. **Operar** un agente de IA con MCP de forma supervisada y trazable.
3. **Ejecutar** el ciclo completo con validación humana en cada fase.
4. **Producir** un informe verificable con hallazgos reproducibles.
5. **Evaluar** críticamente qué aportó la IA y dónde fue necesaria tu intervención.

## 📖 Fases del capstone

| # | Fase                   | Entregable                                               |
|---|------------------------|----------------------------------------------------------|
| 1 | Alcance y autorización | Documento de RoE + guardrails (clase 339).               |
| 2 | Montaje                | kali-mcp operativo contra tu VM (clase 333).             |
| 3 | Recon y auditoría      | Mapa de superficie de ataque validado (clases 334, 336). |
| 4 | PoC supervisada        | Demostración de impacto de bajo riesgo (clase 335).      |
| 5 | Informe                | Reporte verificado con evidencia (clase 338).            |
| 6 | Retrospectiva          | Análisis crítico del uso de IA.                          |

## Definiciones y características

---

**Capstone** : Proyecto integrador que exige aplicar, de forma coherente y completa, competencias de todo el programa en un caso realista y acotado.

**Documento de alcance (RoE)** : Define objetivos, límites, ventana y autorización. Aquí lo redactas tú para tu propio laboratorio; en el mundo real lo firma el cliente.

**Evidencia reproducible** : Cada hallazgo del informe puede repetirse manualmente con la herramienta correspondiente, sin depender de la palabra de la IA.

## Herramientas y preparación

---

- Una **VM vulnerable propia** (Metasploitable, DVWA, o el [lab appsec-web](#)) en red aislada.
- **kali-mcp** montado (clase 333) y tu cliente de IA con MCP.
- El [lab kali-mcp-ia](#) del programa como guía de montaje.

## Desarrollo guiado

---

1. **Escribe tu RoE + guardrails.** Alcance = tu VM; matriz de permisos; política de datos; registro de auditoría.
2. **Monta kali-mcp** y verifica el aislamiento de red del contenedor.
3. **Recon y auditoría asistidos**, validando manualmente cada hallazgo clave.
4. **Elige y aprueba** un vector de PoC de bajo impacto; ejecútalo con trazabilidad.
5. **Post-explotación mínima** para demostrar impacto, sin tocar datos ni salir de alcance.
6. **Genera el informe** con IA y **verifica** cada hallazgo contra la evidencia.
7. **Retrospectiva:** ¿qué aceleró la IA? ¿qué alucinó? ¿dónde fue imprescindible tu criterio?

## Ejercicios

---

1. Redacta el documento de alcance/RoE de tu capstone.
2. Diseña la matriz de permisos del agente para esta operación.
3. Define cómo registrarás la trazabilidad de cada acción.
4. Especifica los límites de post-explotación que respetarás.
5. Prepara la plantilla del informe final.

## Reto verificable (entregable del capstone)

---

Un **paquete de engagement** de tu laboratorio que incluya: (a) RoE + guardrails, (b) registro de auditoría de la sesión, (c) informe con hallazgos **reproducibles**, y (d) una retrospectiva crítica del uso de IA.

**Criterio de aceptación:** todo ocurrió dentro del alcance (tu VM); cada acción con impacto fue aprobada por ti; cada hallazgo del informe es reproducible manualmente; la retrospectiva identifica al menos un aporte real de la IA y al menos una limitación (p. ej. una alucinación) que tu supervisión corrigió.

## Errores comunes

| Síntoma / mensaje                        | Causa y cómo arreglar                                              |
|------------------------------------------|--------------------------------------------------------------------|
| Empezar sin RoE ni alcance               | Nunca. Define y limita el alcance por escrito antes de tocar nada. |
| Hallazgos no reproducibles en el informe | Verifica todo a mano; elimina lo que no puedas respaldar.          |
| Dejar que el agente actúe sin aprobación | Rompe la supervisión. Aprueba cada acción con impacto.             |
| Objetivo fuera de tu propiedad           | Ilegal. Solo tu laboratorio.                                       |
| Retrospectiva ausente                    | Pierdes el aprendizaje. Analiza críticamente el uso de IA.         |

## Preguntas frecuentes

 **¿Qué nivel de autonomía le doy al agente en el capstone?** El mínimo para ser útil: recon y resúmenes pueden ser más automáticos; toda acción activa o con impacto requiere tu aprobación. Tú firmas el informe.

 **¿Y si la IA se equivoca en un hallazgo?** Por eso verificas todo contra la evidencia. Documentar una alucinación que tu supervisión corrigió es, de hecho, parte del aprendizaje del capstone.

 **¿Esto es el final del programa?** Sí: integra técnica ofensiva/defensiva con IA como copiloto. A partir de aquí, sigue practicando en tu home lab y mantente al día — el campo cambia rápido.

## Referencias

- kali-mcp (MIT) — <https://github.com/pabpereza/kali-mcp>
- PTES · OWASP Top 10 for LLM
- [Lab kali-mcp-ia](#) y capstones de la [Parte 16](#).

## Siguiente clase

[Volver al índice del programa](#)